

Reporte Ejecutivo de Auditoría de Seguridad

1. Resumen Ejecutivo

Score de Seguridad General: 85 / 100

Justificación del Score: El servidor presenta una configuración de seguridad inicial sólida, utilizando una versión reciente y soportada de Ubuntu y un kernel actualizado. No se detectaron servicios de alto riesgo como Telnet o FTP. Las deducciones de puntos se deben principalmente a la exposición del servicio SSH y la presencia de múltiples cuentas de usuario interactivas, lo que aumenta la superficie de ataque y requiere una gestión de seguridad más rigurosa.

Evaluación Gerencial

El servidor auditado opera con un sistema operativo y kernel actualizados, lo que proporciona una base de seguridad robusta. Sin embargo, se identificaron áreas clave para mejorar la postura de seguridad, principalmente relacionadas con la configuración del acceso remoto SSH y la gestión de cuentas de usuario. No se encontraron vulnerabilidades críticas inmediatas ni servicios de alto riesgo expuestos, pero la implementación de las recomendaciones propuestas fortalecerá significativamente la resiliencia del sistema frente a posibles ataques.

2. Hallazgos Prioritarios

- Exposición del servicio SSH (puerto 22) a la red, lo que lo convierte en un objetivo potencial para ataques de fuerza bruta.
- Presencia de dos cuentas de usuario con acceso interactivo (/bin/bash), lo que aumenta la superficie de ataque y la necesidad de una gestión de credenciales robusta.
- Ausencia de un análisis explícito de vulnerabilidades (CVEs) para la versión específica del kernel, lo que impide una evaluación completa de su estado de seguridad.

3. Matriz de Riesgos Detectados

ID	Riesgo Detectado	Nivel de Impacto	Descripción
----	------------------	------------------	-------------

R-01	Exposición del servicio SSH	Alto	El servicio SSH (puerto 22/tcp) está expuesto a la red, lo que lo convierte en un objetivo potencial para ataques de fuerza bruta o intentos de acceso no autorizado si no está configurado con las mejores prácticas de seguridad (ej. autenticación por clave, deshabilitar root, cambio de puerto).
R-02	Múltiples cuentas de usuario interactivas	Medio	Existen dos cuentas de usuario con shell interactiva (/bin/bash), lo que aumenta la superficie de ataque y el riesgo de compromiso si las credenciales son débiles o si una de las cuentas es comprometida. Es crucial asegurar que solo usuarios autorizados y necesarios tengan acceso interactivo.
R-03	Potenciales vulnerabilidades en el kernel sin confirmar	Medio	Aunque el kernel (6.8.0-124-generic) es relativamente reciente, la ausencia de un análisis explícito de CVEs conocidos para esta versión específica impide confirmar su estado de seguridad actual. Podría haber vulnerabilidades no parcheadas que podrían ser explotadas.

4. Recomendaciones Técnicas de Mitigación

■ ■ Fortalecer la seguridad del servicio SSH

Cambiar el puerto por defecto de SSH, deshabilitar el acceso directo de root y la autenticación por contraseña (favoreciendo el uso de claves SSH) reduce drásticamente la superficie de ataque y la exposición a ataques de fuerza bruta.

```
sudo sed -i 's/#Port 22/Port 2222/' /etc/ssh/sshd_config
sudo sed -i 's/#PermitRootLogin prohibit-password/PermitRootLogin no/' /etc/ssh/sshd_config
sudo sed -i 's/#PasswordAuthentication yes/PasswordAuthentication no/' /etc/ssh/sshd_config
sudo systemctl restart sshd
```

■ ■ Revisar y gestionar cuentas de usuario interactivas

Implementar políticas de contraseñas robustas y revisar la necesidad de múltiples cuentas interactivas. Si no son estrictamente necesarias, se deberían deshabilitar o configurar con shells no interactivas. Establecer una caducidad de contraseña obliga a los usuarios a cambiarlas periódicamente.

```
sudo apt update && sudo apt install -y libpam-pwquality
sudo pam-auth-update --enable pwquality
sudo chage -M 90 User_2
sudo chage -M 90 User_3
```

■ ■ Mantener el sistema operativo y kernel actualizados

Aplicar regularmente las actualizaciones de seguridad del sistema operativo y del kernel es fundamental para mitigar vulnerabilidades conocidas y asegurar la estabilidad y seguridad del sistema. Un reinicio puede ser necesario tras una actualización del kernel.

```
sudo apt update
sudo apt upgrade -y
sudo apt dist-upgrade -y
sudo apt autoremove -y
sudo reboot
```

■ ■ Implementar un escaneo de vulnerabilidades continuo

Realizar escaneos de vulnerabilidades periódicos con herramientas especializadas para identificar y abordar proactivamente cualquier debilidad en el sistema operativo, el kernel y las aplicaciones instaladas, incluyendo la detección de CVEs específicos para la versión del kernel.